

PERSONAL DATA PROCESSING AGREEMENT

Annex A to the IntelliBase AI Service Subscription Agreement No.:

This Agreement governs how the Provider processes data on behalf of the Customer under Indonesian Law No. 27 of 2022 on Personal Data Protection (the "PDP Law").

1. PARTIES AND ROLES

1. The **Customer**,, is the **Personal Data Controller**. The Customer decides what data is uploaded, who is given access, and for what purpose.
2. The **Provider**,, owner of the IntelliBase AI service, is the **Personal Data Processor**. The Provider processes data only on the Customer's documented instructions, namely the Subscription Agreement, this Agreement, and the configuration set by the Customer's administrator within the Service.
3. If the Provider considers an instruction to breach the PDP Law, it shall promptly inform the Customer and may suspend carrying it out.
4. Customer's data protection contact: (email:). Provider's contact: hello@intellibaseai.com.

2. DETAILS OF PROCESSING

Item	Details
Purpose	Answering Users' questions based on the Customer's internal documents, managing accounts and quotas, Service security, billing
Data subjects	The Customer's employees and administrators who hold accounts; people named in the Customer's internal documents
Account data	Name, email, unit/department, role, 2FA status, password (stored as a hash)
Document content	Extracted text, text chunks, embedding vectors, automatic summary. The original file is not retained after extraction.
Activity	Questions, AI answers with source citations, thumbs up/down feedback
Technical data	IP address and operational logs at infrastructure providers (maximum 90 days)
Excluded data	Medical records and identifiable patient health data, unless agreed in writing in an addendum with additional safeguards
Duration	For as long as the Subscription Agreement is in force, plus the deletion period in Section 5

Health data is specific personal data under Article 4 of the PDP Law. The exclusion above therefore applies by default.

3. PROCESSOR OBLIGATIONS AND SECURITY MEASURES

1. Process data only for the purposes in Section 2 and not sell, rent or use it for the Provider's own purposes.
2. Limit access to Customer data to Provider personnel who need it to run the Service, and bind them to confidentiality.
3. Apply the following technical security measures, and not reduce them while this Agreement is in force:

Measure	Implementation
Tenant isolation	PostgreSQL row-level security: every query on customer data is restricted to the company ID at the database level, so an application code error cannot expose another customer's data
Encryption in transit	HTTPS/TLS for all traffic, HSTS enabled
Encryption at rest	Storage encryption by the database provider; Customer-supplied API keys (BYOK) additionally encrypted with AES-256-GCM
Authentication	Passwords stored as hashes, two-factor authentication (2FA) available, public API keys stored as hashes
Access control	Administrator and employee roles, authorisation checks on every endpoint
Application protection	Per-IP rate limiting, Content Security Policy, automated security scanning (DAST)

4. Assist the Customer in meeting its PDP Law obligations, including responding to data subject requests and data protection impact assessments, on request.

4. SUB-PROCESSORS AND TRANSFERS OUTSIDE INDONESIA

The Customer approves the following sub-processors. All of them process data outside the Republic of Indonesia.

Sub-processor	Function	Data received
Google LLC (Gemini API)	Document indexing (embedding); fallback answer generation	Full document content; questions and document excerpts when the fallback is active
Groq Inc.	Answer generation and document summaries	Questions, relevant document excerpts, roughly the first 2,000 characters of each document
Neon Inc. (AWS ap-southeast-1, Singapore)	Database	All stored data
Vercel Inc.	Application hosting	Data in transit while requests are processed, operational logs
Resend	Transactional email	Recipient name and email
Midtrans	Payment processing	Transaction data

Slack (if enabled by the Customer)	Chat integration	Questions and answers in the Customer's Slack channels
------------------------------------	------------------	--

1. **Use of data for AI model training.** Groq states it does not use API data for training. The Provider's Gemini account on the free tier permits Google to use content to improve its services, including model training. The Parties choose (tick one):
☐ (a) The Provider uses a paid-tier Gemini account, which does not use data for training, no later than the start date of the Agreement.
☐ (b) The Customer installs its own Gemini and Groq API keys (BYOK), so data is processed under the Customer's own agreement with those providers.
2. The Provider notifies the Customer at least 30 days before adding or replacing a sub-processor. The Customer may terminate the Agreement without penalty if it objects.
3. The Provider selects sub-processors that provide a level of data protection at least equivalent to the PDP Law, as required by Article 56 of the PDP Law for transfers outside Indonesian jurisdiction.

5. INCIDENTS, DATA SUBJECT RIGHTS, AUDIT AND DELETION

1. **Incidents.** The Provider notifies the Customer no later than 48 hours after becoming aware of a personal data protection failure involving Customer data, so the Customer can meet its 3 x 24 hour notification duty under Article 46 of the PDP Law.
2. The notification states: the data affected, the estimated time and cause, the steps taken and planned, and the Provider's contact person.
3. **Data subject rights.** Access, correction or deletion requests from data subjects received by the Provider are forwarded to the Customer within 3 business days. The Provider helps carry them out within 30 days via hello@intellibaseai.com.
4. **Audit.** The Customer may request, at most once a year, a written description of the security measures and sub-processors in place. On-site or third-party audits may be agreed at the Customer's cost.
5. **Deletion.** The Customer's administrator can delete documents at any time; their text, chunks and vectors are permanently removed from the live database immediately.
6. After the Agreement ends, at the Customer's request, the Provider exports chat history within 30 days, then deletes all Customer data no later than 30 days after the deletion request. Automated backup copies at the database provider are removed according to the backup retention cycle.
7. Payment transaction records are excluded from deletion and kept in line with bookkeeping obligations.
8. This Agreement is made in Indonesian and English. In the event of any discrepancy, the Indonesian version prevails.

PROVIDER (PROCESSOR)

Date:

CUSTOMER (CONTROLLER)

Date:

(.....)

Title:

(.....)

Title: